FirstPass

Clearing the contract-review queue, and how I think.

A working prototype, a live console, and measured results,
built to run entirely on your own servers.

RISK TRIAGE

RED escalate

AMBER confirm

GREEN auto-clear

🔒 on-prem · local AI · no cloud

Abdelrhman Rayis

AI Pioneer · work-sample presentation

WHAT I'LL COVER

Five short steps, the way I'd tackle any new problem.

1. **How I approach a problem I have not seen before**
   First principles, five whys, systems thinking, 80/20.
2. **The scenario, and its root cause**
   Your contract queue, and why it really backs up.
3. **FirstPass: the solution, running live**
   An agentic triage layer, in a browser, on your server.
4. **Does it actually help?**
   Measured properly: safety, accuracy, hours saved.
5. **Private by design, and how I would add value**
   Local AI, the standards that matter, and my fit.

THE PLAN

Value from day one: a skill that grows into an agentic loop.

DAY 1	DAY 2	WEEK 1	WEEK 2
1 Skill	**2 Agent memory**	**3 System**	**4 Agentic loop**
Deploy the contract-triage skill, after understanding the business.	The playbook becomes the agent's memory of standard positions.	The console, routing and evals grow around it.	The full loop, with the learning flywheel.

↺ Feedback loop: gather feedback and improve every two weeks. The queue gets shorter each cycle.

WHERE IT RUNS

Cloud, fast: synthetic test data, no GDPR issue › **🔒 Local Hermes, on your server: real data**

When real client data is involved, reasoning moves in-house. Value fast, privacy kept.

HOW I THINK

I don't jump to a solution. I find the root of the problem first.

Four mental models I reach for before writing a line of code:

First principles

Strip the task to its atoms. What is really being decided here?

Five whys

Keep asking why until the symptom gives up its root cause.

Systems thinking

Look at the whole flow. Where is the constraint, and the leverage?

80 / 20

Find the small share of cases that carries most of the value and risk.

The point: a creative solution is worthless if it solves the wrong problem. Models keep me honest.

THE SCENARIO

The case in front of me: a queue longer than the day.

"Most are 80% boilerplate. Where we get redlines, they are usually edits we have seen before. Right now, every single contract still gets read by a person, and the queue is usually longer than the day. At end of month or quarter it can get overwhelming."

PortSwigger, the task brief

80%

of a typical contract is boilerplate, agreed a hundred times before

100%

still get a full cold read by a scarce, expensive human

EoQ

sales spikes turn the queue into a bottleneck on revenue

The cost is not just time. A slow queue slows every deal sitting behind it.

FIVE WHYS

Drilling past the symptom to the root of the issue.

1	**Why is the queue longer than the day?**	› Every contract gets a full human read.
2	**Why does each one need a full read?**	› It is read cold, start to finish, every time.
3	**Why is it read cold?**	› There is no way to tell the safe ones from the risky ones up front.
4	**Why can't we tell them apart?**	› The team's standard positions live in people's heads, not in a checkable form.
5	**Why is that the case?**	› The process was built around people, with no triage layer in front of it.

ROOT CAUSE

A lawyer's scarce attention is spent identically on the safe 80% and the risky 20%. There is no risk-based triage. That is what I need to fix, not the reading speed.

FIRST PRINCIPLES

Reframed: contract review is a risk gate, not a reading task.

Strip it to the atoms and every review is the same five decisions:

1. Read ›
2. Classify ›
3. Compare to standard ›
4. Spot the deviation ›
5. Accept / redline / escalate

THE INSIGHT

Only two of those five steps need legal judgement. The rest is mechanical.

80% of contracts are boilerplate, and the redlines that come up are edits seen before: a finite, reusable playbook. So the share needing net-new legal thinking is small, and it shrinks as the playbook fills. Yet today one scarce resource, a lawyer's attention, is spent identically on the safe 80% and the risky 20%.

SYSTEMS THINKING

The fix is structural: insert a triage layer.

TODAY

NDA | Form | NDA | Form › **one human queue**

Every item pays the same full cost. Volume spikes have nowhere to go.

WITH FIRSTPASS

contracts › **triage layer**

- **GREEN auto-clear**
- **AMBER confirm**
- **RED escalate**

You already do this

Burp Suite triages security findings by severity so humans focus on the real threats. FirstPass is the same move, pointed at the contract queue.

Leverage point: route attention by risk, so human judgement flows only to the 20% that needs it.

The process, its friction, and the right fix at each step.

Not everything should be AI. I picked the right tool for each point in the process.

Intake & parse	Mixed formats, manual logging, no priority **Auto-ingest and extract. This is n8n / RPA territory.**	AUTOMATION
Classify & pull terms	Implicit, redone by hand every time **The model reads and understands the document.**	AGENTIC
Check the playbook	Standard positions live in people's heads **Retrieve the position, match the clause by meaning.**	AGENTIC
Spot risk & red flags	Fatigue, and the risky 20% slips through **Rules for hard flags, the agent for paraphrase and novelty.**	HYBRID
Draft redline & route	Re-writing edits seen before; first-in-first-out **Draft from the playbook, score GREEN / AMBER / RED.**	AGENTIC
Decide & capture	Nothing is learned; novel issues re-solved each time **The lawyer decides RED; the decision feeds the knowledge base.**	HUMAN + LOOP

THE SOLUTION

One agentic loop: contract in, a routed and redlined decision out.

1 Ingest › 2 Classify › 3 Retrieve playbook › 4 Detect › 5 Score › 6 Draft redline › 7 Route

8 LEARN the lawyer's decision is written back to the playbook, so next time it is routine

GREEN

Auto-clear with a spot-check. Never auto-signed.

AMBER

Known deviation. The redline is already drafted. Lawyer confirms.

RED

Novel or high risk. Escalate with terms and issues pre-extracted.

WHY AN AGENTIC LOOP, NOT N8N

Deterministic automation is the wrong tool for a judgement task.

n8n, Zapier and RPA are excellent when the logic can be fully specified up front. Contract wording never can: it is unstructured, endlessly paraphrased, and full of clauses no fixed rule has seen. That is a reasoning problem, not a plumbing one.

WHAT THE JOB NEEDS	n8n / RPA	Rules only	Agentic loop
Move data and call APIs (the plumbing)	✓	~	~
Understand unstructured contract language	–	~	✓
Handle paraphrased or novel clauses	–	–	✓
Apply a risk policy and judgement	–	~	✓
Improve from feedback over time	–	–	✓
Explainable, with a human in the loop	~	✓	✓

Not either / or: n8n moves the contracts, the agentic loop reviews them. Deterministic automation for the pipes, an agentic loop for the judgement, a human on the risky 20%.

IT RUNS TODAY

A working console, not a mockup.

FirstPass

Every contract gets an AI first pass. A human confirms.

🔒 Running **on-prem** · local model · no cloud

5 escalate to a human (novel or high-risk)

3 confirm pre-drafted redlines

2 auto-cleared with a spot-check

3.2h human review time saved on this queue (60%)

5/10 contracts handled without a cold human read · queue sorted by risk

STATUS	CONTRACT	TYPE	ISSUES	TIME SAVED	
RED	nda_indemnity_umbrella	Mutual Non-Disclosure Agreement	4	14 min	Review ›
RED	orderform_uncapped_tyrell	Customer Order Form	3	10 min	Review ›
RED	nda_broaddef_hooli	Mutual Non-Disclosure Agreement	2	14 min	Review ›
RED	nda_noncompete_soylent	Mutual Non-Disclosure Agreement	2	14 min	Review ›
RED	nda_novel_wayne	Mutual Non-Disclosure Agreement	2	14 min	Review ›
AMBER	nda_perpetual_initech	Mutual Non-Disclosure Agreement	3	27 min	Review ›
AMBER	nda_oneway_globex	Mutual Non-Disclosure Agreement	2	27 min	Review ›
AMBER	orderform_net90_cyberdyne	Customer Order Form	2	17 min	Review ›
GREEN	nda_clean_acme	Mutual Non-Disclosure Agreement	0	33 min	Review ›
GREEN	orderform_clean_stark	Customer Order Form	0	23 min	Review ›

The queue a lawyer opens each morning.

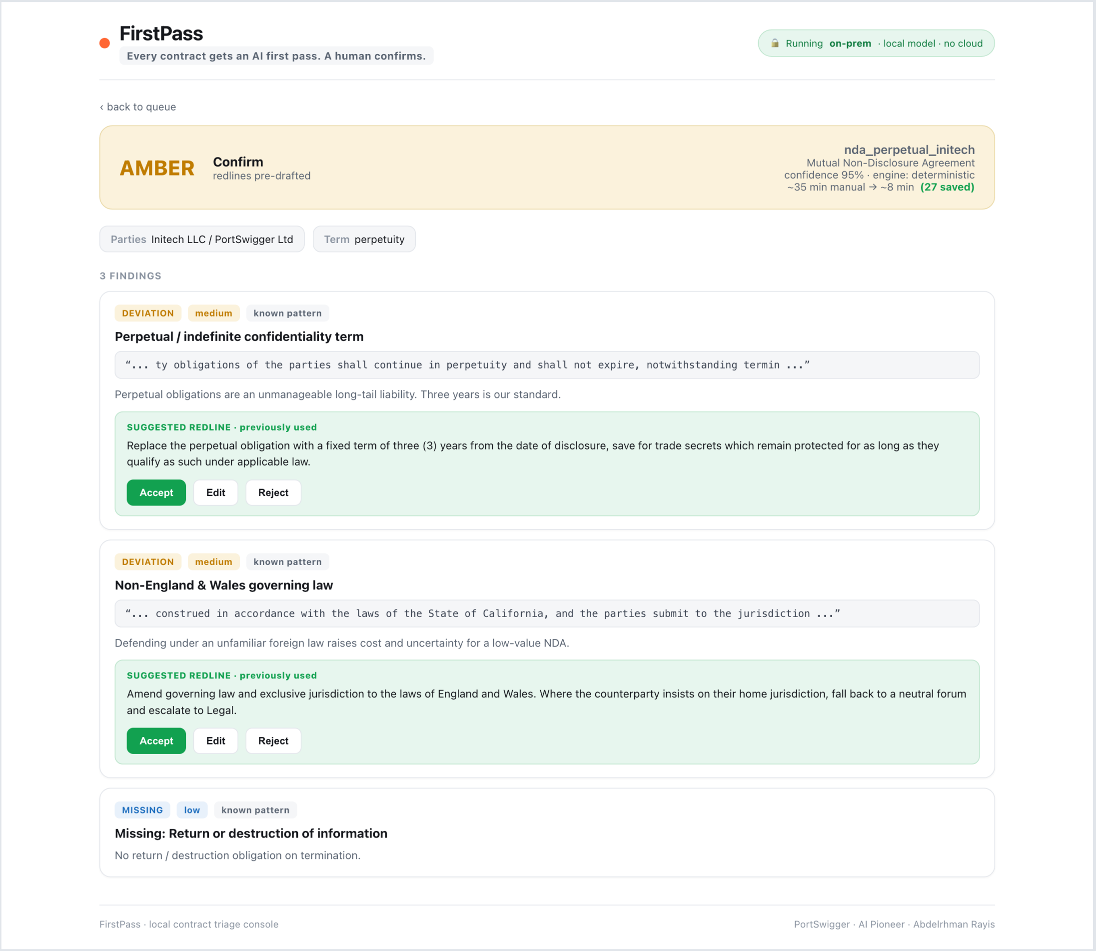
Sorted by risk. The safe 80% is already cleared, the redlines are drafted, and only the real risk is waiting for a human.

🔒 Runs on your server

In-browser, local, offline. No contract text ever leaves the building.

INSIDE A REVIEW

Every issue arrives with the redline already drafted.



The lawyer confirms, they do not start from scratch.

Key terms extracted. Each deviation shows the evidence, the plain-English reason, and the exact redline the team has used before.

Accept, edit or reject. One click.

This is the artefact someone uses on Monday morning.

DOES IT HELP?

Measured properly, on a labelled set, reproducibly.

0

unsafe misses: nothing risky was auto-cleared

100%

triage verdict accuracy (10 of 10)

93 / 93

material-issue precision / recall, no LLM

58%

of human review minutes removed

EXTRAPOLATED TO 200 CONTRACTS / MONTH

~73 hours

of legal time returned every month, about two weeks of a reviewer, pointed back at real risk.

EXTERNAL BENCHMARK · LAWGEEX 2018

94% vs 85% **AI beat 20 lawyers at NDA issue-spotting**

26 sec vs 92 min **average review time**

The category is proven. This applies it to your queue, privately.

IT GETS SMARTER

A knowledge base and a skill set that grow with every case.

A lawyer resolves a novel case › **It becomes a rule in the knowledge base** › **That case is now routine, redline ready** › **Next month's queue is shorter**

KNOWLEDGE BASE

The playbook is plain English. Every decision a lawyer makes is captured as a rule with the redline they used. It fills with PortSwigger's own positions, so the system knows more each week.

SKILLS THAT COMPOUND

A new contract type or clause is not new code, it is a new skill added to the playbook. The agent's abilities grow without an engineer, and none of it is lost when I leave.

Demonstrated: python evals/demo_learning.py closes the one gap the eval found, recall 93% to 100%, one playbook edit, no code.

PRIVATE BY DESIGN

Local AI on your server, and built to the standards that matter.

WHY LOCAL

Contracts are privileged and confidential, and you are a security company. So the reasoning model runs on your own server, not a third-party API. No contract text ever leaves your infrastructure: privacy is kept by construction, not by policy.

HOW

The deterministic engine needs no model at all: that is the floor. The reasoning layer is an open-weight model (Hermes 3, Llama 3.3, Qwen, Mistral) served locally with Ollama or vLLM. It ships as a skill on day one, then moves fully in-house.

BUILT TO THE STANDARDS THAT MATTER

UK GDPR / DPA 2018

Personal data in contracts, handled lawfully

ISO/IEC 27001

Information security, on-prem by default

ISO/IEC 42001

AI management system, governed and audited

EU AI Act / NIST AI RMF

Human-in-the-loop, explainable, risk-based

MY FIT

Why I applied, and how I would add value here.

WHY I APPLIED

PortSwigger is treating AI as the way it works, not a side project.

I already do this: drop into a domain, build a real thing, measure it, hand it over.

I want to be somewhere the ambition and the tooling are taken seriously.

HOW I ADD VALUE

- **Ship artefacts, not slides**

  A working tool someone uses on Monday.

- **Bring the expert with me**

  I work alongside the domain expert, not above them.

- **Measure everything**

  I care as much about the eval as the build.

- **Leave capability, not dependency**

  The playbook and skills stay when I move on.

Thank you.

This was one corner. There are twenty-five more.

The legal queue was the brief. The method is the point: find the risk gate, insert triage, measure it, keep it private, teach it to compound, then move on.

Legal today. Support, marketing, finance, recruitment next. Same loop, new domain.

Questions?

Abdelrhman Rayis · abdelrhman.rayis@gmail.com

Prototype, live console, evals and this deck are all in the submitted repo.